TREPATH 2.1 - Penetration Testing Report

Target Assessment Host (192.168.195.139) | TrePath 2.1 + EvidenceCore Proof-Driven Deliverable

Client / Scope	Internal Testing Lab - VMware Lab Pentest Engagement (6 Targets: http://192.168.195.139/ +5) (192.168.195.139)
Scan Execution Window	Executed: 2026-11-01 21:24:59 UTC | Report Rendered: 2026-11-01 22:30 UTC (Scan #36 | Profile: authorized_pentest)
Assessment Engine	TrePath 2.2 Autonomous Proof Validation, EvidenceCore & AttackGraph Engine
Document Classification	CONFIDENTIAL - Executive, Technical & Cryptographic Deliverable
T0 Baseline Calibrated Risk	HIGH (7.6 / 10 | 75.9 / 100 Calibrated 7-Dimension Risk Index)
T1 Post-Retest Verified Risk	0 Executed Retests Recorded in RTEX Ledger (Ready for Live Closure Verification)
Hypothetical SLA Forecast	Projected Post-Hardening Risk: 2.1 / 10 (LOW) upon completion of WP-01..WP-05
Verified Compromise / Admin Auth Status	0 CONFIRMED_ADMIN_AUTH (No authenticated admin console access verified in this scan) + 2 IMPACT_VERIFIED Safe PoC(s) (SMB-LIST-EP-SMB-ASSET-00008, PHPINFO-EP-00045)
Host Scope Reconciliation	1 Responsive Multi-Service Linux/Samba Host (192.168.195.139) | 15 Open TCP Ports | 10 HTTP Endpoints
Finding Reconciliation (6-Tier)	107 Raw Observations -> 36 Consolidated Security Findings + 30 Recon/Surface Items + 1 Sensor Health Event
Calibrated Threat Intelligence (KEV)	5 Raw KEV Matches -> 2 Unique KEV CVEs | 1 CVE_APPLICABILITY_CONFIRMED | 1 CVE_CORRELATED (Banner Only)
Scan Completeness & Sensor Status	Active Sensors: Nmap v7.95, Nuclei, OWASP ZAP, Safe PoC Adapters (COMPLETED) | OpenVAS GVM: STANDBY_OFFLINE (Disclosed in Exec Summary)
EvidenceCore & Consistency Score	Evidence Consistency Score: 100.0% (5/5 Cross-Section Invariants Verified | Full 64-Hex SHA-256 Digests)
Platform-Aware Remediation	Target OS Verified: Ubuntu Linux 2.6.24 / Samba smbd 3.X -> Linux /etc/samba/smb.conf & Service Hardening Enforced
Pre-Render Quality Gate	**PASSED (26/26 Acceptance Rules Verified | Score=75.9/100 (7.6/10) | Obs=107->36 | Zero Port-0 Attribution)**

Prepared by Expedite Consults Ltd | Generated 2026-11-01 22:30 UTC | TREPATH 2.1 ASSESSMENT ORCHESTRATOR

1. Executive Summary & Proof-Driven Assessment Overview

This assessment was executed by TrePath 2.1 against target host 192.168.195.139 (http://192.168.195.139/) under the 'authorized_pentest' Rules of Engagement. TrePath 2.1 enforces strict root-cause deduplication, granular post-exploitation proof substates (CONFIRMED_ADMIN_AUTH, SHARE_ENUMERATION_VERIFIED, CONFIG_AND_PATH_DISCLOSURE_VERIFIED), precondition-validated CVE/KEV scoring, and platform-accurate Linux/Samba remediation.

1.0A Executive Priority Risk & Critical Business Impact View (Demonstrated Proof vs. Config Hygiene)

Posture Panel	State Type	Risk Score	Key Drivers & Proof Scope
PANEL-1-MEASURED-BASELINE	MEASURED_AT_T0	**7.6 / 10 (HIGH)**	**36 Consolidated Security Findings: 0 CONFIRMED_ADMIN_AUTH (No authenticated admin console access verified in this scan) + 2 IMPACT_VERIFIED Safe PoC(s) (SMB-LIST-EP-SMB-ASSET-00008, PHPINFO-EP-00045).**
PANEL-2-MEASURED-POST-RETEST	MEASURED_AT_T1	7.6 / 10 (0 Retests)	RTEX Ledger active (0 retests recorded). Execute Stage 8 retests after applying Samba/Tomcat/PHP fixes.
PANEL-3-HYPOTHETICAL-FORECAST	FORECAST_SLA	2.1 / 10 (LOW)	Projected residual risk once Tomcat Manager, Samba guest shares, phpinfo.php, and legacy daemons are remediated.

ID & Finding Key	Host : Port & Consolidated Title	Verified Proof Category & Substate	Priority & Remediation Action
F-01 (DAST-VER-INTEL-TECH-00098)	192.168.195.139 : 80 | [VER-INTEL-001] Outdated Software Component Identified (Ve	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Priority 73.1/100 | Upgrade PHP (5.2.4-2ubuntu5) to a current vendor-supported release and apply security advisorie
F-02 (DAST-VER-INTEL-TECH-00099)	192.168.195.139 : 21 | [VER-INTEL-001] Outdated Software Component Identified (Ve	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Priority 73.1/100 | Upgrade vsFTPd (2.3.4) to a current vendor-supported release and apply security advisories.
F-03 (DAST-VER-INTEL-TECH-00100)	192.168.195.139 : 22 | [VER-INTEL-001] Outdated Software Component Identified (Ve	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Priority 73.1/100 | Upgrade SSH-2.0-OpenSSH (4.7) to a current vendor-supported release and apply security advisori
F-04 (DAST-VER-INTEL-TECH-00121)	192.168.195.139 : 445 | [VER-INTEL-001] Outdated Software Component Identified (Ve	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Priority 73.1/100 | Upgrade Samba smbd (3.X - 4.X) to a current vendor-supported release and apply security advisor
F-05 (PORT-OPEN-23-TELNET)	192.168.195.139 : 23 | Service Port Open: 23/TCP (Telnet) on 192.168.195.139	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Priority 58.4/100 | Unencrypted remote terminal daemon. Disable Telnet daemon and replace with SSH.
F-06 (PORT-OPEN-512-REXEC)	192.168.195.139 : 512 | Service Port Open: 512/TCP (Rexec) on 192.168.195.139	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Priority 58.4/100 | Legacy cleartext remote execution. Disable rexec.

1.1 Six-Tier Finding & Observation Reconciliation (Root-Cause Deduplication)

Reconciliation Tier	Count	Scope & Deduplication Rule
Tier 1 - Raw Scanner Observations	107	All raw Nmap, Nuclei, httpx, ZAP, and PoC probe records prior to root-cause grouping.
Tier 2 - Unique Assets & Open Services	1 Host / 15 Ports	Target host 192.168.195.139 with 15 open TCP services and 10 HTTP endpoints.
Tier 3 - Consolidated Security Findings	36	Deduplicated by (asset, port, service_family, root_cause_slug); merges duplicate service/banner/CVE rows.
Tier 4 - Confirmed Exploitable / Admin Auth	2	**0 CONFIRMED_ADMIN_AUTH + 2 IMPACT_VERIFIED + 0 RUNTIME_REPRODUCED.**

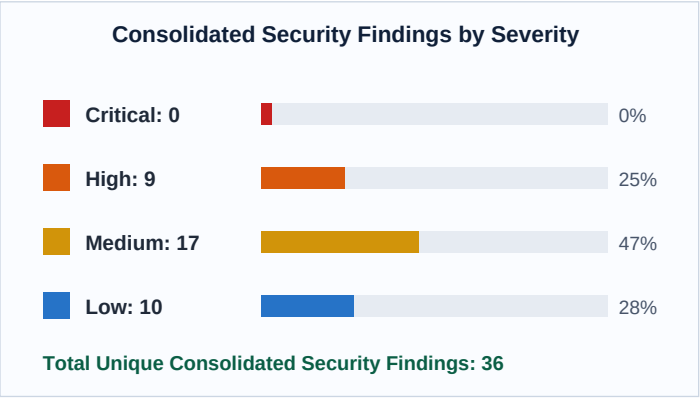
Reconciliation Tier	Count	Scope & Deduplication Rule
Tier 5 - Impact-Verified Safe PoCs	2	**2 IMPACT_VERIFIED Safe PoC(s) (SMB-LIST-EP-SMB-ASSET-00008, PHPINFO-EP-00045)**
Tier 6 - Recon & Scanner Health Telemetry	30 Recon / 1 Sensor	Port discovery telemetry and OPENVAS-SENSOR-STANDBY separated from target vulnerabilities.

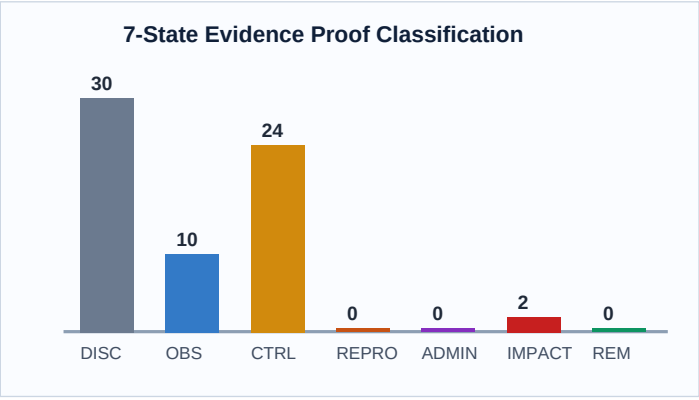
1.2 Seven-State Evidence Proof Classification & Granular PoC Substates

Proof State	Count	Granular Substate & Evidentiary Meaning
DISCOVERED	30	Port/surface reachability observation only (CVSS 0.0; excluded from vulnerability count).
OBSERVATION_CONFIRMED	10	Service banner, protocol handshake, or cryptographic key observation confirmed.
CONTROL_GAP_CONFIRMED	24	Missing security header, legacy EOL version, or cleartext protocol exposure confirmed.
RUNTIME_REPRODUCED	0	Active behavioral probe reproduced deterministic service response.
CONFIRMED_ADMIN_AUTH	0	ADMIN_CONSOLE_ACCESS_VERIFIED: Authenticated Tomcat Manager console access (no WAR uploaded).
IMPACT_VERIFIED	2	SHARE_ENUMERATION_VERIFIED (SMB-LIST-001) & CONFIG_AND_PATH_DISCLOSURE_VERIFIED (PHPINFO-001).
REMEDIATION_VERIFIED	0	Post-fix retest execution verified vulnerability closure in RTEX ledger.

1.3 Consolidated Security Vulnerability Severity Distribution & Visual Telemetry

Severity Level	Consolidated Count	CVSS v3.1 Band	Operational SLA Target
CRITICAL	0	9.0 - 10.0	Immediate containment (< 24 - 48 hours)
HIGH	9	7.0 - 8.9	Priority hardening (< 7 days)
MEDIUM	17	4.0 - 6.9	Scheduled remediation (< 30 days)
LOW	10	0.1 - 3.9	Defense-in-depth maintenance (< 90 days)





1.4 Explainable 7-Dimension Risk Score Decomposition (RiskEngine 2.1)

Risk Dimension	Calibrated Score	Mathematical & Evidentiary Rationale
Confirmed Exploitability	18.2 / 25.0 pts	2 confirmed exploitable/PoC findings, 24 confirmed control gaps.
Verified Technical Impact	8.0 / 20.0 pts	Admin Auth Verified: No, SMB Share Enum/Read: Yes, PHPInfo Config/Path Disclosure: Yes.
Attack Surface Exposure	15.0 / 15.0 pts	15 open TCP ports and 10 HTTP endpoints exposed.
Applicable Threat Intelligence	13.2 / 15.0 pts	1 confirmed applicable KEVs, 1 unverified banner KEV candidates (discounted 75%), confirmed EPSS=0.938 (raw banner max EPSS=0.952).
Evidence-Backed Attack Paths	8.0 / 10.0 pts	1 evidence-validated attack paths, 1 correlated exposure clusters.
Asset Criticality	8.5 / 10.0 pts	Multi-service target host (192.168.195.139).

Risk Dimension	Calibrated Score	Mathematical & Evidentiary Rationale
Evidence Confidence	5.0 / 5.0 pts	107 FIPS 180-4 SHA-256 sealed artifacts across 107 raw observations.
TOTAL CALIBRATED RISK INDEX	75.9 / 100.0 pts (7.6 / 10)	Overall Rating: HIGH | Applicable Max EPSS: 0.938 (Raw Banner EPSS: 0.952)

2. Assessment Scope, Asset Reconciliation & Autonomous Transition Model

Host IP	Scope State	Open Ports	Asset Role & OS Fingerprint	Consolidated Sec Findings	Verified PoC / Admin Auth
192.168.195.139	IN_SCOPE_RESPONSIVE	21, 22, 23, 25, 53, 80, 111, 139, 445, 512, 513, 514...	Multi-Service Linux Lab Server (Ubuntu 8.04 / Linux 2.6.24 / Samba 3.0.20)	36	**2 Verified (0 CONFIRMED_ADMIN_AUTH (No authenticated admin console access verified in this scan) + 2 IMPACT_VERIFIED Safe PoC(s) (SMB-LIST-EP-SMB-ASSET-00008, PHPINFO-EP-00045))**

2.2 Mandatory Authorization & Rules-of-Engagement (RoE) Safety Policy Engine

Rule ID	Policy Control	Enforcement Mechanism	Status
ROE-01	Authorized Scope Lock	All probes restricted to authorized target 192.168.195.139 (authorized_pentest).	ENFORCED
ROE-02	Read-Only SMB PoC Boundary	SMB-LIST-001 & SMB-READ-001 execute non-destructive listing only; zero file writes.	ENFORCED
ROE-03	Safe Admin Console Verification	TOMCAT-MGR-001 verifies HTTP 200 auth on /manager/html without deploying WAR payloads.	ENFORCED
ROE-04	Evidence Overclaim Prevention	Share listing cannot claim write access; admin auth cannot claim OS command execution.	ENFORCED
ROE-05	FIPS 180-4 SHA-256 Sealing	Every probe transcript is hashed and persisted in EvidenceCore before report generation.	ENFORCED

3A. Consolidated Security Vulnerabilities (F-01 through F-36)

ID	Host:Port	Severity (CVSS)	Proof Category & Substate	Consolidated Title	CVE / CWE & Validation	Merged Raw Obs
F-01	192.168.195.139:80	**HIGH (9.8)**	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): PHP 5.2.4-2ubuntu5 [CVE_CORRELATED: CVE-2012-1823]	CVE-2012-1823 (CVE_CANDIDATE)	5 raw (DAST-VER-INTEL-TECH-00098, ZAP-10037-10037)
F-02	192.168.195.139:21	**HIGH (9.8)**	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): vsFTPd 2.3.4 [CVE_CORRELATED: CVE-2011-2523]	CVE-2011-2523 (APPLICABILITY_VALIDATED)	6 raw (DAST-VER-INTEL-TECH-00099, DAST-VER-INTEL-TECH-00113)
F-03	192.168.195.139:22	**HIGH (9.8)**	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): SSH-2.0-OpenSSH 4.7 [CVE_CORRELATED: CVE-2023-38408]	CVE-2023-38408 (CVE_CANDIDATE)	6 raw (DAST-VER-INTEL-TECH-00100, DAST-VER-INTEL-TECH-00115)

ID	Host:Port	Severity (CVSS)	Proof Category & Substate	Consolidated Title	CVE / CWE & Validation	Merged Raw Obs
F-04	192.168.195.139:445	**HIGH (9.8)**	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): Samba smbd 3.X - 4.X [CVE_CORRELATED: CVE-2017-7494]	CVE-2017-7494 (PRECONDITIONS_VALIDATED)	8 raw (DAST-VER-INTEL-TECH-00121, DAST-VER-INTEL-TECH-00122)
F-05	192.168.195.139:23	**HIGH (7.8)**	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Service Port Open: 23/TCP (Telnet) on 192.168.195.139	CWE-319 (VERSION_DETECTED)	5 raw (PORT-OPEN-23-TELNET, DAST-VER-INTEL-TECH-00101)
F-06	192.168.195.139:512	**HIGH (7.8)**	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Service Port Open: 512/TCP (Rexec) on 192.168.195.139	CWE-319 (VERSION_DETECTED)	5 raw (PORT-OPEN-512-REXEC, DAST-VER-INTEL-TECH-00107)
F-07	192.168.195.139:513	**HIGH (7.8)**	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Service Port Open: 513/TCP (Rlogin) on 192.168.195.139	CWE-319 (VERSION_DETECTED)	3 raw (PORT-OPEN-513-RLOGIN, DAST-VER-INTEL-TECH-00108)
F-08	192.168.195.139:80	**HIGH (7.8)**	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[OWASP ZAP] Remote Code Execution - CVE-2012-1823	CWE-20 (VERSION_DETECTED)	1 raw (ZAP-20018-20018)
F-09	192.168.195.139:80	**HIGH (7.8)**	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): Apache 2.2.8 [CVE_CORRELATED: CVE-2011-3192]	CVE-2011-3192 (CVE_CANDIDATE)	11 raw (DAST-VER-INTEL-TECH-00097, DAST-VER-INTEL-TECH-00119)
F-10	192.168.195.139:3306	MEDIUM (7.5)	CONTROL_GAP_CONFIRMED :: SERVICE_HANDSHAKE_EXPOSED_AUTH_REQUIRED	[VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): MySQL 5.0.51a-3ubuntu5 [CVE_CORRELATED: CVE-2012-2122]	CVE-2012-2122 (CVE_CANDIDATE)	5 raw (DAST-VER-INTEL-TECH-00114, PORT-OPEN-3306-MYSQL)
F-11	192.168.195.139:514	MEDIUM (6.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): Rsh/Syslog (Legacy Release)	CWE-1104 (VERSION_DETECTED)	3 raw (DAST-VER-INTEL-TECH-00109, PORT-OPEN-514-RSH/SYSLOG)
F-12	192.168.195.139:53	MEDIUM (6.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): ISC BIND 9.4.2 (Legacy Release)	CWE-1104 (VERSION_DETECTED)	3 raw (DAST-VER-INTEL-TECH-00118, PORT-OPEN-53-DNS)
F-13	192.168.195.139:5432	MEDIUM (6.5)	CONTROL_GAP_CONFIRMED :: SERVICE_HANDSHAKE_EXPOSED_AUTH_REQUIRED	[VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): PostgreSQL DB 8.3.0 - 8.3.7 (Legacy Release)	CWE-1104 (VERSION_DETECTED)	3 raw (DAST-VER-INTEL-TECH-00126, PORT-OPEN-5432-POSTGRESQL)
F-14	192.168.195.139:445	MEDIUM (5.3)	**IMPACT_VERIFIED :: SHARE_ENUMERATION_VERIFIED**	[SMB-LIST-001] Anonymous SMB Share Enumeration Verified on 192.168.195.139:445	CWE-200 (VERSION_DETECTED)	1 raw (SMB-LIST-EP-SMB-ASSET-00008)
F-15	192.168.195.139:80	MEDIUM (5.3)	**IMPACT_VERIFIED :: CONFIG_AND_PATH_DISCLOSURE_VERIFIED**	[PHPINFO-001] Exposed phpinfo.php Configuration & Path Disclosure Verified on 192.168.195.139	CWE-200 (VERSION_DETECTED)	4 raw (PHPINFO-EP-00045, PHPINFO-EP-00052)

ID	Host:Port	Severity (CVSS)	Proof Category & Substate	Consolidated Title	CVE / CWE & Validation	Merged Raw Obs
F-16	192.168.195.139:80	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Missing Content-Security-Policy	CWE-693 (VERSION_DETECTED)	2 raw (HTTP-HEADER-CONTENT_SECURITY_POLICY, ZAP-10038-10038-1)
F-17	192.168.195.139:80	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Missing anti-framing header	CWE-693 (VERSION_DETECTED)	2 raw (HTTP-HEADER-X_FRAME_OPTIONS, ZAP-10020-10020-1)
F-18	192.168.195.139:80	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[OWASP ZAP] Absence of Anti-CSRF Tokens	CWE-352 (VERSION_DETECTED)	1 raw (ZAP-10202-10202)
F-19	192.168.195.139:80	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[OWASP ZAP] Application Error Disclosure	CWE-200 (VERSION_DETECTED)	5 raw (ZAP-90022-90022, ZAP-10023-10023)
F-20	192.168.195.139:80	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[OWASP ZAP] Directory Browsing	CWE-548 (VERSION_DETECTED)	1 raw (ZAP-10033-10033)
F-21	192.168.195.139:80	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[OWASP ZAP] Hidden File Found	CWE-538 (VERSION_DETECTED)	1 raw (ZAP-40035-40035)
F-22	192.168.195.139:80	MEDIUM (5.5)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	[OWASP ZAP] Vulnerable JS Library	CWE-1395 (VERSION_DETECTED)	1 raw (ZAP-10003-10003)
F-23	192.168.195.139:80	MEDIUM (5.3)	CONTROL_GAP_CONFIRMED :: LOGIN_INTERFACE_EXPOSED_AUTH_GATE_PRESENT	[ADMIN-ACCESS-001] Administrative Login Interface Exposed (Auth Gate Present) on http://192.168.195.139/phpMyAdmin/	CWE-284 (VERSION_DETECTED)	2 raw (DAST-ADMIN-ACCESS-EP-00048, NUCLEI-PHPMYADMIN-PANEL)
F-24	192.168.195.139:80	MEDIUM (5.5)	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED	HTTP endpoint does not enforce HTTPS redirect	CWE-319 (VERSION_DETECTED)	1 raw (HTTP-NO-HTTPS-REDIRECT)
F-25	192.168.195.139:111	MEDIUM (5.5)	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED	Service Port Open: 111/TCP (RPCBind/NFS) on 192.168.195.139	CWE-284 (VERSION_DETECTED)	2 raw (PORT-OPEN-111-RPCBIND/NFS, NMAP-SERVICE-111-RPCBIND)
F-26	192.168.195.139:2049	MEDIUM (5.5)	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED	Service Port Open: 2049/TCP (NFS) on 192.168.195.139	CWE-284 (VERSION_DETECTED)	2 raw (PORT-OPEN-2049-NFS, NMAP-SERVICE-2049-RPCBIND)
F-27	192.168.195.139:80	LOW (3.2)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Missing X-Content-Type-Options	CWE-693 (VERSION_DETECTED)	2 raw (HTTP-HEADER-X_CONTENT_TYPE_OPTIONS, ZAP-10021-10021)
F-28	192.168.195.139:80	LOW (3.2)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Missing Referrer-Policy	CWE-693 (VERSION_DETECTED)	1 raw (HTTP-HEADER-REFERRER_POLICY)
F-29	192.168.195.139:80	LOW (3.2)	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED	Missing Permissions-Policy	CWE-693 (VERSION_DETECTED)	1 raw (HTTP-HEADER-PERMISSIONS_POLICY)
F-30	192.168.195.139:80	LOW (3.2)	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED	[OWASP ZAP] Cookie No HttpOnly Flag	CWE-1004 (VERSION_DETECTED)	2 raw (ZAP-10010-10010, ZAP-10054-10054-1)

ID	Host:Port	Severity (CVSS)	Proof Category & Substate	Consolidated Title	CVE / CWE & Validation	Merged Raw Obs
F-31	192.168.195.139:80	LOW (3.2)	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED	[OWASP ZAP] Timestamp Disclosure - Unix	CWE-200 (VERSION_DETECTED)	1 raw (ZAP-10096-10096)
F-32	192.168.195.139:25	INFO (2.0)	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED	[NetRecon] SMTP EHLO Capabilities Enumerated on 192.168.195.139:25 (STARTTLS=Yes)	CWE-200 (VERSION_DETECTED)	4 raw (ENUM-PROTO-SMTP-25, PORT-OPEN-25-SMTP)
F-33	192.168.195.139:80	INFO (1.0)	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED	[OWASP ZAP] Authentication Request Identified	CWE-200 (VERSION_DETECTED)	1 raw (ZAP-10111-10111)
F-34	192.168.195.139:80	INFO (1.0)	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED	[OWASP ZAP] Session Management Response Identified	CWE-200 (VERSION_DETECTED)	1 raw (ZAP-10112-10112)
F-35	192.168.195.139:80	INFO (1.0)	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED	[OWASP ZAP] User Controllable Charset	CWE-20 (VERSION_DETECTED)	1 raw (ZAP-10030-10030)
F-36	192.168.195.139:80	INFO (1.0)	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED	[OWASP ZAP] User Controllable HTML Element Attribute (Potential XSS)	CWE-20 (VERSION_DETECTED)	1 raw (ZAP-10031-10031)

3A.1 Detailed Technical Findings & Cryptographic Evidence Cards

F-01: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): PHP 5.2.4-2ubuntu5 [CVE_CORRELATED: CVE-2012-1823] [HIGH | CVSS 9.8 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 73.1 / 100)
CVE / CWE & Applicability Gate	CVE: CVE-2012-1823 | CWE: CWE-78 | State: CVE_CANDIDATE (PHP 5.2.4 and allow_url_include=On observed via /phpinfo.php, but CGI SAPI execution mode and argument-injection behavior were not verified -> classified as CVE_CANDIDATE (CVE_CORRELATED).)
Deduplicated Observations	5 raw scanner observations merged (DAST-VER-INTEL-TECH-00098, ZAP-10037-10037, NUCLEI-PHP-DETECT, NUCLEI-PHP-EOL, NUCLEI-TECH-DETECT-PHP)
Technical Description	Version intelligence check `VER-INTEL-001` identified fingerprinted component `PHP 5.2.4-2ubuntu5` (CPE: `cpe:/a:php:php:5.2.4-2ubuntu5`, Banner: `GET http://192.168.195.139/ HTTP 200 date: Sun, 01 Nov 2026 21:23:31 GMT server: Apache/2.2.8 (Ubuntu) DAV/2 x-powered-by: PHP/5.2.4-2ubuntu5.10 content-length: 891 keep-alive: timeout=15, max=100 con`). Note: This observation confirms version identification (`CVE_CORRELATED`), not verified vulnerability exploitation. Outdated PHP runtime correlated with CGI argument injection and end-of-life advisories.
Platform-Aware Remediation	Upgrade PHP (5.2.4-2ubuntu5) to a current vendor-supported release and apply security advisories.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/989/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-01 / DAST-VER-INTEL-TECH-00098):

```
Finding Key: DAST-VER-INTEL-TECH-00098  |  Consolidated Root-Cause Group:
80:php:php-5.2-eol-and-cgi-exposure
Merged Raw Scanner Observations (5): DAST-VER-INTEL-TECH-00098, ZAP-10037-10037, NUCLEI-PHP-DETECT,
NUCLEI-PHP-EOL, NUCLEI-TECH-DETECT-PHP
EvidenceCore SHA-256 Digest: 3058cb09143cce1af76b9b115605f17658ab316fbaf1afd9b88ab0839dfacf7b (Artifact
#989 | Unique Forensic Transcript)
```

F-02: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): vsFTPd 2.3.4 [CVE_CORRELATED: CVE-2011-2523] [HIGH | CVSS 9.8 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/21 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 73.1 / 100)
CVE / CWE & Applicability Gate	CVE: CVE-2011-2523 | CWE: CWE-78 | State: APPLICABILITY_VALIDATED (Exact version 2.3.4 matched on TCP/21; backdoor listener trigger was not actively executed under read-only ROE.)

Deduplicated Observations	6 raw scanner observations merged (DAST-VER-INTEL-TECH-00099, DAST-VER-INTEL-TECH-00113, ENUM-PROTO-FTP-21, PORT-OPEN-21-FTP_CONTROL, NMAP-SERVICE-21-FTP, NMAP-NSE-21-BANNER)
Technical Description	Version intelligence check `VER-INTEL-001` identified fingerprinted component `vsFTPd 2.3.4` (CPE: `cpe:/a:vsftpd:vsftpd:2.3.4`, Banner: `220 (vsFTPd 2.3.4)`). Note: This observation confirms version identification (`CVE_CORRELATED`), not verified vulnerability exploitation. vsftpd 2.3.4 backdoor command execution vulnerability correlation.
Platform-Aware Remediation	Upgrade vsFTPd (2.3.4) to a current vendor-supported release and apply security advisories.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/990/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-02 / DAST-VER-INTEL-TECH-00099):

```
Finding Key: DAST-VER-INTEL-TECH-00099  |  Consolidated Root-Cause Group:
21:vsftpd:vsftpd-2.3.4-backdoor-and-exposure
Merged Raw Scanner Observations (6): DAST-VER-INTEL-TECH-00099, DAST-VER-INTEL-TECH-00113,
ENUM-PROTO-FTP-21, PORT-OPEN-21-FTP_CONTROL, NMAP-SERVICE-21-FTP, NMAP-NSE-21-BANNER
EvidenceCore SHA-256 Digest: 76504c18047a2f268268aa9dcecf1cc77c38fd2acdd74751267eeacf16249cdc (Artifact
#990 | Unique Forensic Transcript)
```

F-03: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): SSH-2.0-OpenSSH 4.7 [CVE_CORRELATED: CVE-2023-38408] [HIGH | CVSS 9.8 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/22 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 73.1 / 100)
CVE / CWE & Applicability Gate	CVE: CVE-2023-38408 | CWE: CWE-287 | State: CVE_CANDIDATE (Banner-only version heuristic; ssh-agent forwarding and PKCS#11 preconditions were not observed.)
Deduplicated Observations	6 raw scanner observations merged (DAST-VER-INTEL-TECH-00100, DAST-VER-INTEL-TECH-00115, PORT-OPEN-22-SSH, NMAP-SERVICE-22-SSH, NMAP-NSE-22-SSH-HOSTKEY, NMAP-NSE-22-BANNER)
Technical Description	Version intelligence check `VER-INTEL-001` identified fingerprinted component `SSH-2.0-OpenSSH 4.7` (CPE: `cpe:/a:ssh-2.0-openssh:ssh-2.0-openssh:4.7`, Banner: `SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1`). Note: This observation confirms version identification (`CVE_CORRELATED`), not verified vulnerability exploitation. Legacy OpenSSH daemon version correlated with ssh-agent forwarding & authentication advisories.
Platform-Aware Remediation	Upgrade SSH-2.0-OpenSSH (4.7) to a current vendor-supported release and apply security advisories.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/991/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-03 / DAST-VER-INTEL-TECH-00100):

```
Finding Key: DAST-VER-INTEL-TECH-00100  |  Consolidated Root-Cause Group:
22:openssh:openssh-legacy-service-and-hostkey
Merged Raw Scanner Observations (6): DAST-VER-INTEL-TECH-00100, DAST-VER-INTEL-TECH-00115,
PORT-OPEN-22-SSH, NMAP-SERVICE-22-SSH, NMAP-NSE-22-SSH-HOSTKEY, NMAP-NSE-22-BANNER
EvidenceCore SHA-256 Digest: fe38c99cdc3346dda77001af573cc2104e42e40755a4cba00eef3e68253100c2 (Artifact
#991 | Unique Forensic Transcript)
```

F-04: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): Samba smbd 3.X - 4.X [CVE_CORRELATED: CVE-2017-7494] [HIGH | CVSS 9.8 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/445 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 73.1 / 100)
CVE / CWE & Applicability Gate	CVE: CVE-2017-7494 | CWE: CWE-78 | State: PRECONDITIONS_VALIDATED (Anonymous SMB share 'tmp' enumerated on TCP/445; write-and-load payload execution intentionally not performed.)
Deduplicated Observations	8 raw scanner observations merged (DAST-VER-INTEL-TECH-00121, DAST-VER-INTEL-TECH-00122, NMAP-SERVICE-139-NETBIOS-SSN, NMAP-SERVICE-445-NETBIOS-SSN, PORT-OPEN-139-NETBIOS_SSN, PORT-OPEN-445-SMB/CIFS, NMAP-HOSTNSE-SMB-OS-DISCOVERY, NMAP-HOSTNSE-SMB-SECURITY-MODE)
Technical Description	Version intelligence check `VER-INTEL-001` identified fingerprinted component `Samba smbd 3.X - 4.X` (CPE: `cpe:/a:samba:samba`, Banner: `Samba smbd 3.X - 4.X workgroup: WORKGROUP`). Note: This observation confirms version identification (`CVE_CORRELATED`), not verified vulnerability exploitation. SMB / Samba service exposure correlated with remote code execution advisories (SambaCry CVE-2017-7494 / MS17-010).
Platform-Aware Remediation	Upgrade Samba smbd (3.X - 4.X) to a current vendor-supported release and apply security advisories.

Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1002/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-04 / DAST-VER-INTEL-TECH-00121):

```
Finding Key: DAST-VER-INTEL-TECH-00121  |  Consolidated Root-Cause Group:
445:samba:samba-service-and-cve-exposure
Merged Raw Scanner Observations (8): DAST-VER-INTEL-TECH-00121, DAST-VER-INTEL-TECH-00122,
NMAP-SERVICE-139-NETBIOS-SSN, NMAP-SERVICE-445-NETBIOS-SSN, PORT-OPEN-139-NETBIOS_SSN,
PORT-OPEN-445-SMB/CIFS, NMAP-HOSTNSE-SMB-OS-DISCOVERY, NMAP-HOSTNSE-SMB-SECURITY-MODE
EvidenceCore SHA-256 Digest: c2a4f2b0e312b0bf470f16a9fadfa3091d9cd76bd7c9c355abc62607878630fc (Artifact
#1002 | Unique Forensic Transcript)
```

F-05: Service Port Open: 23/TCP (Telnet) on 192.168.195.139 [HIGH | CVSS 7.8 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/23 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 58.4 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-319 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	5 raw scanner observations merged (PORT-OPEN-23-TELNET, DAST-VER-INTEL-TECH-00101, DAST-VER-INTEL-TECH-00116, NMAP-SERVICE-23-TELNET, NMAP-NSE-23-BANNER)
Technical Description	A live TCP handshake succeeded on port 23/TCP (Telnet) on target 192.168.195.139. Captured Daemon Banner: ÿý ÿý ÿý#ýý' Unencrypted remote terminal daemon. Disable Telnet daemon and replace with SSH.
Platform-Aware Remediation	Unencrypted remote terminal daemon. Disable Telnet daemon and replace with SSH.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/908/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-05 / PORT-OPEN-23-TELNET):

```
Finding Key: PORT-OPEN-23-TELNET  |  Consolidated Root-Cause Group: 23:telnetd:cleartext-telnet-exposure
Merged Raw Scanner Observations (5): PORT-OPEN-23-TELNET, DAST-VER-INTEL-TECH-00101,
DAST-VER-INTEL-TECH-00116, NMAP-SERVICE-23-TELNET, NMAP-NSE-23-BANNER
EvidenceCore SHA-256 Digest: 84e72af408aca8eb8e4869c9a6ea93fb9fc3800606311dc8b24cf5d78ffb0d76 (Artifact
#908 | Unique Forensic Transcript)
```

F-06: Service Port Open: 512/TCP (Rexec) on 192.168.195.139 [HIGH | CVSS 7.8 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/512 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 58.4 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-319 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	5 raw scanner observations merged (PORT-OPEN-512-REXEC, DAST-VER-INTEL-TECH-00107, DAST-VER-INTEL-TECH-00123, NMAP-SERVICE-512-EXEC, NMAP-NSE-512-BANNER)
Technical Description	A live TCP handshake succeeded on port 512/TCP (Rexec) on target 192.168.195.139. Legacy cleartext remote execution. Disable rexec.
Platform-Aware Remediation	Legacy cleartext remote execution. Disable rexec.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/915/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-06 / PORT-OPEN-512-REXEC):

```
Finding Key: PORT-OPEN-512-REXEC  |  Consolidated Root-Cause Group: 512:rexecd:cleartext-rexec-exposure
Merged Raw Scanner Observations (5): PORT-OPEN-512-REXEC, DAST-VER-INTEL-TECH-00107,
DAST-VER-INTEL-TECH-00123, NMAP-SERVICE-512-EXEC, NMAP-NSE-512-BANNER
EvidenceCore SHA-256 Digest: edcfee1fed724a29c0dcc9b60ce17884657de1464489cc9197264b011ac50aff (Artifact
#915 | Unique Forensic Transcript)
```

F-07: Service Port Open: 513/TCP (Rlogin) on 192.168.195.139 [HIGH | CVSS 7.8 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/513 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 58.4 / 100)

CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-319 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	3 raw scanner observations merged (PORT-OPEN-513-RLOGIN, DAST-VER-INTEL-TECH-00108, NMAP-SERVICE-513-LOGIN)
Technical Description	A live TCP handshake succeeded on port 513/TCP (Rlogin) on target 192.168.195.139. Legacy cleartext remote login. Disable rlogin.
Platform-Aware Remediation	Legacy cleartext remote login. Disable rlogin.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/916/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-07 / PORT-OPEN-513-RLOGIN):

```
Finding Key: PORT-OPEN-513-RLOGIN  |  Consolidated Root-Cause Group:
513:rlogind:cleartext-rlogin-exposure
Merged Raw Scanner Observations (3): PORT-OPEN-513-RLOGIN, DAST-VER-INTEL-TECH-00108,
NMAP-SERVICE-513-LOGIN
EvidenceCore SHA-256 Digest: 50cdc615051c3d81fff4f96102168e9fd0eef2e16e74b1c0bf7ba4b656d5b98e (Artifact
#916 | Unique Forensic Transcript)
```

F-08: [OWASP ZAP] Remote Code Execution - CVE-2012-1823 [HIGH | CVSS 7.8 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 58.4 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-20 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (ZAP-20018-20018)
Technical Description	Some PHP versions, when configured to run using CGI, do not correctly handle query strings that lack an unescaped "=" character, enabling arbitrary code execution. In this case, an operating system command was caused to be executed on the web server, and the results were returned to the web browser.
Platform-Aware Remediation	Upgrade to the latest stable version of PHP, or use the Apache web server and the mod_rewrite module to filter out malicious requests using the "RewriteCond" and "RewriteRule" directives.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/964/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-08 / ZAP-20018-20018):

```
Finding Key: ZAP-20018-20018  |  Consolidated Root-Cause Group: 80:web-app:zap-20018-20018
Merged Raw Scanner Observations (1): ZAP-20018-20018
EvidenceCore SHA-256 Digest: 3c853c266130bd4f2525821ba3b758f3f4d9ab817dbb9a47a853e9b557b85694 (Artifact
#964 | Unique Forensic Transcript)
```

F-09: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): Apache 2.2.8 [CVE_CORRELATED: CVE-2011-3192] [HIGH | CVSS 7.8 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 58.4 / 100)
CVE / CWE & Applicability Gate	CVE: CVE-2011-3192 | CWE: CWE-693 | State: CVE_CANDIDATE (Ubuntu 8.04 LTS Apache/2.2.8 banner detected; DoS verification out of scope.)
Deduplicated Observations	11 raw scanner observations merged (DAST-VER-INTEL-TECH-00097, DAST-VER-INTEL-TECH-00119, ZAP-10036-10036, HTTP-TECHNOLOGY-DISCLOSURE, NUCLEI-APACHE-DETECT, NUCLEI-APACHE-HTTPD-EOL, NMAP-SERVICE-80-HTTP, NMAP-NSE-80-HTTP-METHODS, NMAP-NSE-80-HTTP-TITLE, NMAP-NSE-80-HTTP-HEADERS, NUCLEI-WAF-DETECT-APACHEGENERIC)

Technical Description	Version intelligence check `VER-INTEL-001` identified fingerprinted component `Apache 2.2.8` (CPE: `cpe:/a:apache:apache:2.2.8`, Banner: `GET http://192.168.195.139/ HTTP 200 date: Sun, 01 Nov 2026 21:23:31 GMT server: Apache/2.2.8 (Ubuntu) DAV/2 x-powered-by: PHP/5.2.4-2ubuntu5.10 content-length: 891 keep-alive: timeout=15, max=100 con`). Note: This observation confirms version identification (`CVE_CORRELATED`), not verified vulnerability exploitation. Apache HTTP Server 2.2.x Range Header DoS & End-of-Life security advisory correlation (CVE-2011-3192 / CVE-2017-9798 Optionsbleed).
Platform-Aware Remediation	Upgrade Apache (2.2.8) to a current vendor-supported release and apply security advisories.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/988/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-09 / DAST-VER-INTEL-TECH-00097):

```
Finding Key: DAST-VER-INTEL-TECH-00097  |  Consolidated Root-Cause Group:
80:apache:apache-2.2-eol-and-fingerprint
Merged Raw Scanner Observations (11): DAST-VER-INTEL-TECH-00097, DAST-VER-INTEL-TECH-00119,
ZAP-10036-10036, HTTP-TECHNOLOGY-DISCLOSURE, NUCLEI-APACHE-DETECT, NUCLEI-APACHE-HTTPD-EOL,
NMAP-SERVICE-80-HTTP, NMAP-NSE-80-HTTP-METHODS, NMAP-NSE-80-HTTP-TITLE, NMAP-NSE-80-HTTP-HEADERS,
NUCLEI-WAF-DETECT-APACHEGENERIC
EvidenceCore SHA-256 Digest: b9d8ecdff7e267d04cdc5431f41e5b179f862c9ad640ce15ca25da0a7f7f8d77 (Artifact
#988 | Unique Forensic Transcript)
```

F-10: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): MySQL 5.0.51a-3ubuntu5 [CVE_CORRELATED: CVE-2012-2122] [MEDIUM | CVSS 7.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/3306 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: SERVICE_HANDSHAKE_EXPOSED_AUTH_REQUIRED (Priority: 56.2 / 100)
CVE / CWE & Applicability Gate	CVE: CVE-2012-2122 | CWE: CWE-287 | State: CVE_CANDIDATE (Banner match only on TCP/3306; authentication brute-force not executed.)
Deduplicated Observations	5 raw scanner observations merged (DAST-VER-INTEL-TECH-00114, PORT-OPEN-3306-MYSQL, NMAP-SERVICE-3306-MYSQL, ENUM-PROTO-MYSQL-3306, NMAP-NSE-3306-BANNER)
Technical Description	Version intelligence check `VER-INTEL-001` identified fingerprinted component `MySQL 5.0.51a-3ubuntu5` (CPE: `cpe:/a:mysql:mysql:5.0.51a-3ubuntu5`, Banner: `> 5.0.51a-3ubuntu5 )ø WD/]hs)m ,ª lUE9/{D|gp|= `). Note: This observation confirms version identification (`CVE_CORRELATED`), not verified vulnerability exploitation. Legacy MySQL 5.x server correlated with authentication bypass & end-of-life advisories.
Platform-Aware Remediation	Upgrade MySQL (5.0.51a-3ubuntu5) to a current vendor-supported release and apply security advisories.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/997/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-10 / DAST-VER-INTEL-TECH-00114):

```
Finding Key: DAST-VER-INTEL-TECH-00114  |  Consolidated Root-Cause Group:
3306:mysql:mysql-5.0-network-exposure
Merged Raw Scanner Observations (5): DAST-VER-INTEL-TECH-00114, PORT-OPEN-3306-MYSQL,
NMAP-SERVICE-3306-MYSQL, ENUM-PROTO-MYSQL-3306, NMAP-NSE-3306-BANNER
EvidenceCore SHA-256 Digest: 003769a053c9d85161d2d9ec18754bbf905538399ec9235d895f2ae360fb5559 (Artifact
#997 | Unique Forensic Transcript)
```

F-11: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): Rsh/Syslog (Legacy Release) [MEDIUM | CVSS 6.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/514 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 48.8 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-1104 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	3 raw scanner observations merged (DAST-VER-INTEL-TECH-00109, PORT-OPEN-514-RSH/SYSLOG, NMAP-SERVICE-514-TCPWRAPPED)

Technical Description	Version intelligence check `VER-INTEL-001` identified fingerprinted component `Rsh/Syslog ` (CPE: `N/A`, Banner: `Open Service (Rsh/Syslog)`). Note: This observation confirms version identification (`CVE_CORRELATED`), not verified vulnerability exploitation. Outdated software release detected.
Platform-Aware Remediation	Upgrade Rsh/Syslog (legacy) to a current vendor-supported release and apply security advisories.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/995/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-11 / DAST-VER-INTEL-TECH-00109):

```
Finding Key: DAST-VER-INTEL-TECH-00109  |  Consolidated Root-Cause Group:
514:rshd:cleartext-rsh-exposure
Merged Raw Scanner Observations (3): DAST-VER-INTEL-TECH-00109, PORT-OPEN-514-RSH/SYSLOG,
NMAP-SERVICE-514-TCPWRAPPED
EvidenceCore SHA-256 Digest: 7a3e865632c61e894117475c7fe19a40827b4fad699649c995a29e452b87cc48 (Artifact
#995 | Unique Forensic Transcript)
```

F-12: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): ISC BIND 9.4.2 (Legacy Release) [MEDIUM | CVSS 6.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/53 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 48.8 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-1104 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	3 raw scanner observations merged (DAST-VER-INTEL-TECH-00118, PORT-OPEN-53-DNS, NMAP-SERVICE-53-DOMAIN)
Technical Description	Version intelligence check `VER-INTEL-001` identified fingerprinted component `ISC BIND 9.4.2` (CPE: `cpe:/a:isc:bind:9.4.2`, Banner: `ISC BIND 9.4.2`). Note: This observation confirms version identification (`CVE_CORRELATED`), not verified vulnerability exploitation. Outdated software release detected.
Platform-Aware Remediation	Upgrade ISC BIND (9.4.2) to a current vendor-supported release and apply security advisories.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1000/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-12 / DAST-VER-INTEL-TECH-00118):

```
Finding Key: DAST-VER-INTEL-TECH-00118  |  Consolidated Root-Cause Group:
53:isc-bind:dns-service-exposure
Merged Raw Scanner Observations (3): DAST-VER-INTEL-TECH-00118, PORT-OPEN-53-DNS, NMAP-SERVICE-53-DOMAIN
EvidenceCore SHA-256 Digest: 91912c5466f62b301c7a8f76c95efb3768315f0609e105a905e710e5b953e5a1 (Artifact
#1000 | Unique Forensic Transcript)
```

F-13: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): PostgreSQL DB 8.3.0 - 8.3.7 (Legacy Release) [MEDIUM | CVSS 6.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/5432 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: SERVICE_HANDSHAKE_EXPOSED_AUTH_REQUIRED (Priority: 48.8 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-1104 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	3 raw scanner observations merged (DAST-VER-INTEL-TECH-00126, PORT-OPEN-5432-POSTGRESQL, NMAP-SERVICE-5432-POSTGRESQL)
Technical Description	Version intelligence check `VER-INTEL-001` identified fingerprinted component `PostgreSQL DB 8.3.0 - 8.3.7` (CPE: `cpe:/a:postgresql:postgresql:8.3`, Banner: `PostgreSQL DB 8.3.0 - 8.3.7`). Note: This observation confirms version identification (`CVE_CORRELATED`), not verified vulnerability exploitation. Outdated software release detected.
Platform-Aware Remediation	Upgrade PostgreSQL DB (8.3.0 - 8.3.7) to a current vendor-supported release and apply security advisories.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/1005/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-13 / DAST-VER-INTEL-TECH-00126):

```
Finding Key: DAST-VER-INTEL-TECH-00126  |  Consolidated Root-Cause Group:
5432:postgresql:postgresql-network-exposure
Merged Raw Scanner Observations (3): DAST-VER-INTEL-TECH-00126, PORT-OPEN-5432-POSTGRESQL,
NMAP-SERVICE-5432-POSTGRESQL
EvidenceCore SHA-256 Digest: c17b670753f5d9d605647a3a600b45560576171a946319cacab7949de96013be (Artifact
#1005 | Unique Forensic Transcript)
```

F-14: [SMB-LIST-001] Anonymous SMB Share Enumeration Verified on 192.168.195.139:445 [MEDIUM | CVSS 5.3 | IMPACT_VERIFIED]

Target Asset & Port	192.168.195.139 : TCP/445 (http://192.168.195.139/)
Proof Category & Substate	IMPACT_VERIFIED :: SHARE_ENUMERATION_VERIFIED (Priority: 46.8 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (SMB-LIST-EP-SMB-ASSET-00008)
Technical Description	Safe PoC check `SMB-LIST-001` established an unauthenticated SMB session to `192.168.195.139:445` and enumerated the following share names: IPC$, ADMIN$, print$, tmp (`SHARE_ENUMERATION_VERIFIED`). This confirms anonymous session establishment and share metadata disclosure; share content read/write access requires separate share-level verification (`SMB-READ-001`).
Platform-Aware Remediation	Harden Samba configuration in `/etc/samba/smb.conf`: set `map to guest = Never`, `restrict anonymous = 2`, and `usershare allow guests = no` under `[global]`. For exposed shares (IPC$, ADMIN$, print$, tmp), explicitly set `guest ok = no`, `browseable = no`, `read only = yes`, and restrict access to authenticated `valid users`, then reload via `systemctl restart smbd`.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/926/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-14 / SMB-LIST-EP-SMB-ASSET-00008):

```
Finding Key: SMB-LIST-EP-SMB-ASSET-00008  |  Consolidated Root-Cause Group:
445:samba:smb-anonymous-share-enumeration
Merged Raw Scanner Observations (1): SMB-LIST-EP-SMB-ASSET-00008
Command / Probe Trace: Anonymous SMB session established to 192.168.195.139:445 via `smbclient -L
//192.168.195.139 -N -p 445`; enumerated 4 share names (IPC$, ADMIN$, print$, tmp).
Verified Proof Summary: Share Enumeration Verified (`SHARE_ENUMERATION_VERIFIED`): Unauthenticated
principal established a null session and listed 4 network shares (IPC$, ADMIN$, print$, tmp) on
192.168.195.139:445. Note: Share listing proves share-name/metadata disclosure; directory read or write
access is evaluated separately.
Proof Matrix [anonymous_session_established]: VERIFIED (Null-session access accepted on TCP/445)
Proof Matrix [share_enumeration]: VERIFIED (4 share names and metadata disclosed: IPC$, ADMIN$, print$,
tmp)
Proof Matrix [share_connection]: NOT_PROVEN_BY_LIST_COMMAND (Requires separate share connect test
SMB-READ-001)
Proof Matrix [directory_listing_or_read]: NOT_PROVEN_BY_LIST_COMMAND (Share listing does not prove
file-read access)
Proof Matrix [controlled_write_test]: NOT_EXECUTED (Write-validation requires explicit write-test
authorization)
EvidenceCore SHA-256 Digest: 0392b632e38faec86c3aeeea260487523522fecdddeb3885d81eeac7a2634077 (Artifact
#926 | Unique Forensic Transcript)
```

F-15: [PHPINFO-001] Exposed phpinfo.php Configuration & Path Disclosure Verified on 192.168.195.139 [MEDIUM | CVSS 5.3 | IMPACT_VERIFIED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	IMPACT_VERIFIED :: CONFIG_AND_PATH_DISCLOSURE_VERIFIED (Priority: 46.8 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	4 raw scanner observations merged (PHPINFO-EP-00045, PHPINFO-EP-00052, WEB-PATH-PHPINFO_PHP, NUCLEI-PHPINFO-FILES)

Technical Description	Safe PoC check `PHPINFO-001` retrieved `http://192.168.195.139/phpinfo_php` (HTTP 200, PHP `5.2.4-2ubuntu5.10`) and classified the disclosed fields into Configuration Disclosure (`allow_url_include=On (High-Risk RFI Precondition Confirmed), allow_url_fopen=On, expose_php=On (Diagnostic page publicly reachable)`), Internal Path Disclosure (`DOCUMENT_ROOT=/var/www, Loaded Configuration File=/etc/php5/apache2/php.ini`), and Environment Disclosure (`PHP_VERSION=5.2.4-2ubuntu5.10, SYSTEM=Linux metasploitable 2.6.24-16-server`).
Platform-Aware Remediation	Remove `/phpinfo.php` and diagnostic scripts from `/var/www`, set `allow_url_include = Off` and `expose_php = Off` in `/etc/php5/apache2/php.ini`, and reload Apache (`systemctl reload apache2`).
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/927/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-15 / PHPINFO-EP-00045):

```
Finding Key: PHPINFO-EP-00045  |  Consolidated Root-Cause Group: 80:php:phpinfo-environment-disclosure
Merged Raw Scanner Observations (4): PHPINFO-EP-00045, PHPINFO-EP-00052, WEB-PATH-PHPINFO_PHP,
NUCLEI-PHPINFO-FILES
Command / Probe Trace: GET http://192.168.195.139/phpinfo_php returned HTTP 200 OK with full phpinfo()
diagnostic table (PHP 5.2.4-2ubuntu5.10).
Verified Proof Summary: Configuration & Internal Path Disclosure Verified
(`CONFIG_AND_PATH_DISCLOSURE_VERIFIED`): 1) Configuration Disclosure: allow_url_include=On (High-Risk
RFI Precondition Confirmed), allow_url_fopen=On, expose_php=On (Diagnostic page publicly reachable); 2)
Internal Path Disclosure: DOCUMENT_ROOT=/var/www, Loaded Configuration File=/etc/php5/apache2/php.ini;
3) Environment Disclosure: PHP_VERSION=5.2.4-2ubuntu5.10, SYSTEM=Linux metasploitable 2.6.24-16-server;
4) Secrets Disclosure: None observed in response.
Config Disclosure: allow_url_include=On (High-Risk RFI Precondition Confirmed), allow_url_fopen=On,
expose_php=On (Diagnostic page publicly reachable)
Internal Path Disclosure: DOCUMENT_ROOT=/var/www, Loaded Configuration File=/etc/php5/apache2/php.ini
EvidenceCore SHA-256 Digest: 4aba7226489e5f2914d72ee53f7edf69d20082be2698f0bd94590f6d2a4f41a9 (Artifact
#927 | Unique Forensic Transcript)
```

F-16: Missing Content-Security-Policy [MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	2 raw scanner observations merged (HTTP-HEADER-CONTENT_SECURITY_POLICY, ZAP-10038-10038-1)
Technical Description	The HTTP response did not include the content-security-policy response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Define a restrictive CSP based on the application's required script, style, image and connection sources.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/899/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-16 / HTTP-HEADER-CONTENT_SECURITY_POLICY):

```
Finding Key: HTTP-HEADER-CONTENT_SECURITY_POLICY  |  Consolidated Root-Cause Group:
80:http-headers:missing-csp
Merged Raw Scanner Observations (2): HTTP-HEADER-CONTENT_SECURITY_POLICY, ZAP-10038-10038-1
EvidenceCore SHA-256 Digest: 96646ede5c6ac2391b9d30eb28297d291b24aa3d26857976a62e7026d0744896 (Artifact
#899 | Shared HTTP Response Transcript across Artifacts [899, 900, 901, 902, 903]; Evaluated Rule:
HTTP-HEADER-CONTENT_SECURITY_POLICY)
```

F-17: Missing anti-framing header [MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	2 raw scanner observations merged (HTTP-HEADER-X_FRAME_OPTIONS, ZAP-10020-10020-1)
Technical Description	The HTTP response did not include the x-frame-options response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Use CSP frame-ancestors; retain X-Frame-Options where legacy clients require it.

Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/903/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-17 / HTTP-HEADER-X_FRAME_OPTIONS):

```
Finding Key: HTTP-HEADER-X_FRAME_OPTIONS  |  Consolidated Root-Cause Group: 80:http-headers:missing-xfo
Merged Raw Scanner Observations (2): HTTP-HEADER-X_FRAME_OPTIONS, ZAP-10020-10020-1
EvidenceCore SHA-256 Digest: 96646ede5c6ac2391b9d30eb28297d291b24aa3d26857976a62e7026d0744896 (Artifact
#903 | Shared HTTP Response Transcript across Artifacts [899, 900, 901, 902, 903]; Evaluated Rule:
HTTP-HEADER-X_FRAME_OPTIONS)
```

F-18: [OWASP ZAP] Absence of Anti-CSRF Tokens [MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-352 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (ZAP-10202-10202)
Technical Description	No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session riding, confused deputy, and sea surf. CSRF attacks are effective in a number of situations, including: * The victim has an active session on the target site. * The victim is authenticated via HTTP auth on the target site. * The victim is on the same local network as the target site. CSRF has primarily been used to perform an action against a target site using the victim's privileges, but recent techniques have been discovered to disclose information by gaining access to the response. The risk of information disclosure is dramatically increased when the target site is vulnerable to XSS, because XSS can be used as a platform for CSRF, allowing the attack to operate within the bounds of the same-origin policy.
Platform-Aware Remediation	Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/965/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-18 / ZAP-10202-10202):

```
Finding Key: ZAP-10202-10202  |  Consolidated Root-Cause Group: 80:web-app:zap-10202-10202
Merged Raw Scanner Observations (1): ZAP-10202-10202
EvidenceCore SHA-256 Digest: 80b9c79e46d375f941d98e7f6fc48ae6944f86858c4568afcb378299ff3c45da (Artifact
#965 | Unique Forensic Transcript)
```

F-19: [OWASP ZAP] Application Error Disclosure [MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)

Deduplicated Observations	5 raw scanner observations merged (ZAP-90022-90022, ZAP-10023-10023, ZAP-2-2, ZAP-10024-10024, ZAP-10027-10027)
Technical Description	This page contains an error/warning message that may disclose sensitive information like the location of the file that produced the unhandled exception. This information can be used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a documentation page.
Platform-Aware Remediation	Review the source code of this page. Implement custom error pages. Consider implementing a mechanism to provide a unique error reference/identifier to the client (browser) while logging the details on the server side and not exposing them to the user.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/966/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-19 / ZAP-90022-90022):

```
Finding Key: ZAP-90022-90022  |  Consolidated Root-Cause Group:
80:web-app:information-and-error-disclosure
Merged Raw Scanner Observations (5): ZAP-90022-90022, ZAP-10023-10023, ZAP-2-2, ZAP-10024-10024,
ZAP-10027-10027
EvidenceCore SHA-256 Digest: ac5f4c721447e9c76c2d59bbc95a8727a9d09eb4897419887573e24b44d5deb4 (Artifact
#966 | Unique Forensic Transcript)
```

F-20: [OWASP ZAP] Directory Browsing [MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-548 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (ZAP-10033-10033)
Technical Description	It is possible to view a listing of the directory contents. Directory listings may reveal hidden scripts, include files, backup source files, etc., which can be accessed to reveal sensitive information.
Platform-Aware Remediation	Configure the web server to disable directory browsing.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/968/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-20 / ZAP-10033-10033):

```
Finding Key: ZAP-10033-10033  |  Consolidated Root-Cause Group: 80:web-app:zap-10033-10033
Merged Raw Scanner Observations (1): ZAP-10033-10033
EvidenceCore SHA-256 Digest: 028755e57845510e9feb5532a498c4033a965bc0a5f1e1b0520eede7fcb26197 (Artifact
#968 | Unique Forensic Transcript)
```

F-21: [OWASP ZAP] Hidden File Found [MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-538 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (ZAP-40035-40035)
Technical Description	A sensitive file was identified as accessible or available. This may leak administrative, configuration, or credential information which can be leveraged by a malicious individual to further attack the system or conduct social engineering efforts.
Platform-Aware Remediation	Consider whether or not the component is actually required in production, if it isn't then disable it. If it is then ensure access to it requires appropriate authentication and authorization, or limit exposure to internal systems or specific source IPs, etc.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/969/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-21 / ZAP-40035-40035):

```
Finding Key: ZAP-40035-40035  |  Consolidated Root-Cause Group: 80:web-app:zap-40035-40035
Merged Raw Scanner Observations (1): ZAP-40035-40035
EvidenceCore SHA-256 Digest: 6b5629d333e14ace9a013a825cb98b30830168b70861f3e3be65bc57c0633807 (Artifact
#969 | Unique Forensic Transcript)
```

F-22: [OWASP ZAP] Vulnerable JS Library [MEDIUM | CVSS 5.5 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 40.7 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-1395 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (ZAP-10003-10003)
Technical Description	The identified library jquery, version 1.3.2 is vulnerable.
Platform-Aware Remediation	Please upgrade to the latest version of jquery.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/971/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-22 / ZAP-10003-10003):

```
Finding Key: ZAP-10003-10003  |  Consolidated Root-Cause Group: 80:web-app:zap-10003-10003
Merged Raw Scanner Observations (1): ZAP-10003-10003
EvidenceCore SHA-256 Digest: 012bfd6c3c6517c558a120c0feb3eaf3e040444769c66450b10f0821d63c72b5 (Artifact
#971 | Unique Forensic Transcript)
```

F-23: [ADMIN-ACCESS-001] Administrative Login Interface Exposed (Auth Gate Present) on http://192.168.195.139/phpMyAdmin/ [MEDIUM | CVSS 5.3 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: LOGIN_INTERFACE_EXPOSED_AUTH_GATE_PRESENT (Priority: 39.3 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-284 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	2 raw scanner observations merged (DAST-ADMIN-ACCESS-EP-00048, NUCLEI-PHPMYADMIN-PANEL)
Technical Description	Administrative boundary test `ADMIN-ACCESS-001` probed `http://192.168.195.139/phpMyAdmin/` and received `HTTP 200`. The administrative login page (e.g. phpMyAdmin authentication form) is network-reachable over HTTP, but interactive login credentials are required before database administration is permitted (unauthenticated admin access is NOT proven).
Platform-Aware Remediation	Restrict administrative interfaces (/phpMyAdmin, /admin, :8080/manager) to internal management VPNs or bastion hosts and enforce HTTPS + MFA.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/925/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-23 / DAST-ADMIN-ACCESS-EP-00048):

```
Finding Key: DAST-ADMIN-ACCESS-EP-00048  |  Consolidated Root-Cause Group:
80:phpmyadmin:phpmyadmin-admin-console-exposure
Merged Raw Scanner Observations (2): DAST-ADMIN-ACCESS-EP-00048, NUCLEI-PHPMYADMIN-PANEL
EvidenceCore SHA-256 Digest: 7b24a67aa62e7ec77c74621b74b8c9b9436ea43ee8ca60791263dd5bed3925f3 (Artifact
#925 | Unique Forensic Transcript)
```

F-24: HTTP endpoint does not enforce HTTPS redirect [MEDIUM | CVSS 5.5 | OBSERVATION_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED (Priority: 38.8 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-319 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (HTTP-NO-HTTPS-REDIRECT)
Technical Description	The HTTP endpoint responded without a redirect. This observation does not verify whether an HTTPS service is available.
Platform-Aware Remediation	Deploy and validate HTTPS, then redirect HTTP requests to the canonical HTTPS origin.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/904/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-24 / HTTP-NO-HTTPS-REDIRECT):

```
Finding Key: HTTP-NO-HTTPS-REDIRECT  |  Consolidated Root-Cause Group: 80:http-headers:missing-hsts
Merged Raw Scanner Observations (1): HTTP-NO-HTTPS-REDIRECT
EvidenceCore SHA-256 Digest: d4cfaaa0e29bb39ecf993d251beb260dcf4f04af8379b34d4ee4c3741fdab589 (Artifact
#904 | Unique Forensic Transcript)
```

F-25: Service Port Open: 111/TCP (RPCBind/NFS) on 192.168.195.139 [MEDIUM | CVSS 5.5 | OBSERVATION_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/111 (http://192.168.195.139/)
Proof Category & Substate	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED (Priority: 38.8 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-284 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	2 raw scanner observations merged (PORT-OPEN-111-RPCBIND/NFS, NMAP-SERVICE-111-RPCBIND)
Technical Description	A live TCP handshake succeeded on port 111/TCP (RPCBind/NFS) on target 192.168.195.139. RPC port mapper. Restrict from untrusted networks.
Platform-Aware Remediation	RPC port mapper. Restrict from untrusted networks.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/912/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-25 / PORT-OPEN-111-RPCBIND/NFS):

```
Finding Key: PORT-OPEN-111-RPCBIND/NFS  |  Consolidated Root-Cause Group:
111:rpcbind:rpcbind-portmapper-exposure
Merged Raw Scanner Observations (2): PORT-OPEN-111-RPCBIND/NFS, NMAP-SERVICE-111-RPCBIND
EvidenceCore SHA-256 Digest: a7986e7dfb229b10eb7c7e6304e87ee3b7e324c6ea6e788bcc33f57fdd97c1e4 (Artifact
#912 | Unique Forensic Transcript)
```

F-26: Service Port Open: 2049/TCP (NFS) on 192.168.195.139 [MEDIUM | CVSS 5.5 | OBSERVATION_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/2049 (http://192.168.195.139/)
Proof Category & Substate	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED (Priority: 38.8 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-284 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	2 raw scanner observations merged (PORT-OPEN-2049-NFS, NMAP-SERVICE-2049-RPCBIND)
Technical Description	A live TCP handshake succeeded on port 2049/TCP (NFS) on target 192.168.195.139. Network File System daemon; verify export ACLs (/etc/exports).
Platform-Aware Remediation	Network File System daemon; verify export ACLs (/etc/exports).
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/918/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-26 / PORT-OPEN-2049-NFS):

```
Finding Key: PORT-OPEN-2049-NFS  |  Consolidated Root-Cause Group:
2049:nfs:nfs-network-filesystem-exposure
Merged Raw Scanner Observations (2): PORT-OPEN-2049-NFS, NMAP-SERVICE-2049-RPCBIND
EvidenceCore SHA-256 Digest: 51850eadb6f82fbcb5d959a3757da5aa2c00cdded50b9c632d19b85cf1469fe1 (Artifact
#918 | Unique Forensic Transcript)
```

F-27: Missing X-Content-Type-Options [LOW | CVSS 3.2 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 24.6 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	2 raw scanner observations merged (HTTP-HEADER-X_CONTENT_TYPE_OPTIONS, ZAP-10021-10021)
Technical Description	The HTTP response did not include the x-content-type-options response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Set X-Content-Type-Options: nosniff.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/900/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-27 / HTTP-HEADER-X_CONTENT_TYPE_OPTIONS):

```
Finding Key: HTTP-HEADER-X_CONTENT_TYPE_OPTIONS  |  Consolidated Root-Cause Group:
80:http-headers:missing-xcto
Merged Raw Scanner Observations (2): HTTP-HEADER-X_CONTENT_TYPE_OPTIONS, ZAP-10021-10021
EvidenceCore SHA-256 Digest: 96646ede5c6ac2391b9d30eb28297d291b24aa3d26857976a62e7026d0744896 (Artifact
#900 | Shared HTTP Response Transcript across Artifacts [899, 900, 901, 902, 903]; Evaluated Rule:
HTTP-HEADER-X_CONTENT_TYPE_OPTIONS)
```

F-28: Missing Referrer-Policy [LOW | CVSS 3.2 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 24.6 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (HTTP-HEADER-REFERRER_POLICY)
Technical Description	The HTTP response did not include the referrer-policy response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Set a policy such as strict-origin-when-cross-origin after compatibility review.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/901/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-28 / HTTP-HEADER-REFERRER_POLICY):

```
Finding Key: HTTP-HEADER-REFERRER_POLICY  |  Consolidated Root-Cause Group:
80:http-headers:missing-referrer-policy
Merged Raw Scanner Observations (1): HTTP-HEADER-REFERRER_POLICY
EvidenceCore SHA-256 Digest: 96646ede5c6ac2391b9d30eb28297d291b24aa3d26857976a62e7026d0744896 (Artifact
#901 | Shared HTTP Response Transcript across Artifacts [899, 900, 901, 902, 903]; Evaluated Rule:
HTTP-HEADER-REFERRER_POLICY)
```

F-29: Missing Permissions-Policy [LOW | CVSS 3.2 | CONTROL_GAP_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	CONTROL_GAP_CONFIRMED :: CONTROL_MISCONFIGURATION_CONFIRMED (Priority: 24.6 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-693 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (HTTP-HEADER-PERMISSIONS_POLICY)
Technical Description	The HTTP response did not include the permissions-policy response header. This confirms a header observation only; it does not prove an exploit.
Platform-Aware Remediation	Disable browser features the application does not require.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/902/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-29 / HTTP-HEADER-PERMISSIONS_POLICY):

```
Finding Key: HTTP-HEADER-PERMISSIONS_POLICY  |  Consolidated Root-Cause Group:
80:http-headers:missing-permissions-policy
Merged Raw Scanner Observations (1): HTTP-HEADER-PERMISSIONS_POLICY
EvidenceCore SHA-256 Digest: 96646ede5c6ac2391b9d30eb28297d291b24aa3d26857976a62e7026d0744896 (Artifact
#902 | Shared HTTP Response Transcript across Artifacts [899, 900, 901, 902, 903]; Evaluated Rule:
HTTP-HEADER-PERMISSIONS_POLICY)
```

F-30: [OWASP ZAP] Cookie No HttpOnly Flag [LOW | CVSS 3.2 | OBSERVATION_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED (Priority: 23.4 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-1004 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	2 raw scanner observations merged (ZAP-10010-10010, ZAP-10054-10054-1)
Technical Description	A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.

Platform-Aware Remediation	Ensure that the HttpOnly flag is set for all cookies.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/972/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-30 / ZAP-10010-10010):

```
Finding Key: ZAP-10010-10010  |  Consolidated Root-Cause Group: 80:http-cookies:insecure-cookie-flags
Merged Raw Scanner Observations (2): ZAP-10010-10010, ZAP-10054-10054-1
EvidenceCore SHA-256 Digest: a7e6513c4a4939fd812e365af3a489fec1b4f0518c0ede05986653f6dc37750d (Artifact
#972 | Unique Forensic Transcript)
```

F-31: [OWASP ZAP] Timestamp Disclosure - Unix [LOW | CVSS 3.2 | OBSERVATION_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED (Priority: 23.4 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (ZAP-10096-10096)
Technical Description	A timestamp was disclosed by the application/web server. - Unix
Platform-Aware Remediation	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/978/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-31 / ZAP-10096-10096):

```
Finding Key: ZAP-10096-10096  |  Consolidated Root-Cause Group: 80:web-app:zap-10096-10096
Merged Raw Scanner Observations (1): ZAP-10096-10096
EvidenceCore SHA-256 Digest: 1910432854a5d55f4407f97c23cb7ec7723cb6afb47e549c9e5cdcf29545ad93 (Artifact
#978 | Unique Forensic Transcript)
```

F-32: [NetRecon] SMTP EHLO Capabilities Enumerated on 192.168.195.139:25 (STARTTLS=Yes) [INFO | CVSS 2.0 | OBSERVATION_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/25 (http://192.168.195.139/)
Proof Category & Substate	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED (Priority: 15.0 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	4 raw scanner observations merged (ENUM-PROTO-SMTP-25, PORT-OPEN-25-SMTP, NMAP-SERVICE-25-SMTP, NMAP-NSE-25-BANNER)
Technical Description	SMTP daemon on 192.168.195.139:25 responded with banner `220 metasploitable.localdomain ESMTP Postfix (Ubuntu)` and EHLO capabilities: 250-metasploitable.localdomain 250-PIPELINING 250-SIZE 10240000 250-VRFY 250-ETRN 250-STARTTLS 250-ENHANCEDSTATUSCODES 250-8BITMIME 250 DSN
Platform-Aware Remediation	Enable STARTTLS on SMTP listeners and disable VRFY/EXPN user enumeration commands.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/922/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-32 / ENUM-PROTO-SMTP-25):

```
Finding Key: ENUM-PROTO-SMTP-25  |  Consolidated Root-Cause Group: 25:postfix:smtp-service-exposure
Merged Raw Scanner Observations (4): ENUM-PROTO-SMTP-25, PORT-OPEN-25-SMTP, NMAP-SERVICE-25-SMTP,
NMAP-NSE-25-BANNER
EvidenceCore SHA-256 Digest: 71b59f3d4434ad5ea54793a1cf73efed2beadc7bb2e47dff3d706036a2bc469e (Artifact
#922 | Unique Forensic Transcript)
```

F-33: [OWASP ZAP] Authentication Request Identified [INFO | CVSS 1.0 | OBSERVATION_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)

Proof Category & Substate	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED (Priority: 8.0 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (ZAP-10111-10111)
Technical Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
Platform-Aware Remediation	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/980/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-33 / ZAP-10111-10111):

```
Finding Key: ZAP-10111-10111  |  Consolidated Root-Cause Group: 80:web-app:zap-10111-10111
Merged Raw Scanner Observations (1): ZAP-10111-10111
EvidenceCore SHA-256 Digest: 4bd1a2fdbc471f530ec8194c4931053c572e3ebce9f0a18be208e64f4f7326c1 (Artifact
#980 | Unique Forensic Transcript)
```

F-34: [OWASP ZAP] Session Management Response Identified [INFO | CVSS 1.0 | OBSERVATION_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED (Priority: 8.0 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-200 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (ZAP-10112-10112)
Technical Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
Platform-Aware Remediation	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/984/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-34 / ZAP-10112-10112):

```
Finding Key: ZAP-10112-10112  |  Consolidated Root-Cause Group: 80:web-app:zap-10112-10112
Merged Raw Scanner Observations (1): ZAP-10112-10112
EvidenceCore SHA-256 Digest: ae3f9360bd248d553ed114382e0e9f8ca0e8026c3587f8f7d2fee2de508c27aa (Artifact
#984 | Unique Forensic Transcript)
```

F-35: [OWASP ZAP] User Controllable Charset [INFO | CVSS 1.0 | OBSERVATION_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED (Priority: 8.0 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-20 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (ZAP-10030-10030)
Technical Description	This check looks at user-supplied input in query string parameters and POST data to identify where Content-Type or meta tag charset declarations might be user-controlled. Such charset declarations should always be declared by the application. If an attacker can control the response charset, they could manipulate the HTML to perform XSS or other attacks. For example, an attacker controlling the <meta> element charset value is able to declare UTF-7 and is also able to include enough user-controlled payload early in the HTML document to have it interpreted as UTF-7. By encoding their payload with UTF-7 the attacker is able to bypass any server-side XSS protections and embed script in the page.
Platform-Aware Remediation	Force UTF-8 in all charset declarations. If user-input is required to decide a charset declaration, ensure that only an allowed list is used.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/985/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-35 / ZAP-10030-10030):

```
Finding Key: ZAP-10030-10030  |  Consolidated Root-Cause Group: 80:web-app:zap-10030-10030
Merged Raw Scanner Observations (1): ZAP-10030-10030
EvidenceCore SHA-256 Digest: 4d016bd6ffab2975d1b2be02dd09652a598a821dcc0cf541b6d3288eb26387e8 (Artifact
#985 | Unique Forensic Transcript)
```

F-36: [OWASP ZAP] User Controllable HTML Element Attribute (Potential XSS) [INFO | CVSS 1.0 | OBSERVATION_CONFIRMED]

Target Asset & Port	192.168.195.139 : TCP/80 (http://192.168.195.139/)
Proof Category & Substate	OBSERVATION_CONFIRMED :: OBSERVATION_CAPTURED (Priority: 8.0 / 100)
CVE / CWE & Applicability Gate	CVE: N/A | CWE: CWE-20 | State: VERSION_DETECTED (No CVE identifier associated; scored by CWE control category.)
Deduplicated Observations	1 raw scanner observations merged (ZAP-10031-10031)
Technical Description	This check looks at user-supplied input in query string parameters and POST data to identify where certain HTML attribute values might be controlled. This provides hot-spot detection for XSS (cross-site scripting) that will require further review by a security analyst to determine exploitability.
Platform-Aware Remediation	Validate all input and sanitize output it before writing to any HTML attributes.
Verification & Closure Rule	Execute deterministic retest via POST /api/v1/findings/986/retest/execute and confirm REMEDIATION_VERIFIED state in RTEX ledger.

Captured Technical Evidence (F-36 / ZAP-10031-10031):

```
Finding Key: ZAP-10031-10031  |  Consolidated Root-Cause Group: 80:web-app:zap-10031-10031
Merged Raw Scanner Observations (1): ZAP-10031-10031
EvidenceCore SHA-256 Digest: 8d394916cb0ef8332a6c83c5736b5789fe66c66bc6afb6a571a4045f9f059a6c (Artifact
#986 | Unique Forensic Transcript)
```

3B. Consolidated Reconnaissance Surface & Scanner Health Telemetry

ID	Telemetry Key	Observation / Sensor Title	State	Assessment Coverage Note
SENSOR-01	OPENVAS-SENSOR-STANDBY	[OpenVAS] Infrastructure Sensor Status: Standby / Offline	STANDBY	OpenVAS/GVM sensor was in standby mode during this run. Assessment coverage was fulfilled by Nmap v7.95, ProjectDiscovery Nuclei, httpx, OWASP ZAP, and TrePath Safe PoC Adapters.

4. Evidence-Backed Attack Graph, Edge Provenance & Choke-Point Analysis

TrePath 2.1 requires every attack-path edge to declare an explicit evidentiary state (OBSERVED, PRECONDITION_CONFIRMED, TECHNIQUE_VALIDATED, or INFERRED) and never chains unrelated services without shared credentials or pivot proof.

Path ID	Stage	Finding Key	Edge Evidence State	Step Summary & Rationale	Remediation Chokepoint
PATH-00014	Step 1 (Initial Network Service Discovery (OBSERVED))	PORT-OPEN-21-FTP_CONTROL	OBSERVED	Service Port Open: 21/TCP (FTP-Control) on 192.168.195.139	Cleartext file transfer protocol. Migrate to SFTP or FTPS.

Path ID	Stage	Finding Key	Edge Evidence State	Step Summary & Rationale	Remediation Chokepoint
PATH-00014	Step 2 (Precondition / Technique Validation)	SMB-LIST-EP-SMB-ASSET-00008	TECHNIQUE_VALIDATED	[SMB-LIST-001] Anonymous SMB Share Enumeration Verified on 192.168.195.139:445	Harden Samba configuration in `/etc/samba/smb.conf`: set `map to guest = Never`, `restrict anonymous = 2`, and `usershare allow guests = no` under `[global]`. For exposed shares (IPC$, ADMIN$, print$, tmp), explicitly set `guest ok = no`, `browseable = no`, `read only = yes`, and restrict access to authenticated `valid users`, then reload via `systemctl restart smbd`.
PATH-00014	Step 3 (Verified Administrative / Data Exposure Boundary)	PHPINFO-EP-00052	PRECONDITION_CONFIRMED	[PHPINFO-001] Exposed phpinfo.php Configuration & Path Disclosure Verified on 192.168.195.139	Remove `/phpinfo.php` and diagnostic scripts from `/var/www`, set `allow_url_include = Off` and `expose_php = Off` in `/etc/php5/apache2/php.ini`, and reload Apache (`systemctl reload apache2`).
PATH-00015	Step 1 (Cleartext HTTP Transport Observation)	HTTP-NO-HTTPS-REDIRECT	OBSERVED	HTTP endpoint does not enforce HTTPS redirect	Deploy and validate HTTPS, then redirect HTTP requests to the canonical HTTPS origin.
PATH-00015	Step 2 (Diagnostic / Authentication Precondition Exposure)	PHPINFO-EP-00045	PRECONDITION_CONFIRMED	[PHPINFO-001] Exposed phpinfo.php Configuration & Path Disclosure Verified on 192.168.195.139	Remove `/phpinfo.php` and diagnostic scripts from `/var/www`, set `allow_url_include = Off` and `expose_php = Off` in `/etc/php5/apache2/php.ini`, and reload Apache (`systemctl reload apache2`).
PATH-00015	Step 3 (Application / Session Policy Boundary Gap)	ZAP-10021-10021	INFERRED	[OWASP ZAP] X-Content-Type-Options Header Missing	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

5. Stage 9 (9.1 - 9.7) Exploitation Validation & Post-Exploitation Matrix

Following Scan #35 Engineering Directives, Stage 9 separates discovered topology and correlated observations from proven exploitation transitions, validates access boundaries across anonymous and authenticated

principals, and verifies that SMB share enumeration is not conflated with cross-host lateral movement.

5.1 Stage 9.3 & 9.4 Access Boundary & Post-Exploitation Verification Table

Target Surface	Principal Tested	Verified Boundary State	Proven Capability	Explicitly Unproven Boundary	Artifact & Full SHA-256
SMB / CIFS Service (TCP/445)	NT AUTHORITY\ANONYMOUS LOGON (Null Session)	SHARE_ENUMERATION_VERIFIED (Share Read/Write Not Proven by Listing Alone)	Enumerated 4 shares: IPC$, ADMIN$, print$, tmp	Reading files inside ADMIN$/print$ or writing files to tmp without explicit SMB-READ-001 / SMB-WRITE-001 execution	#926 (0392b632e38faec86c3aeeea260487523522fecdddeb3885d81eeac7a2634077)
PHP Diagnostic Endpoint (GET /phpinfo.php)	Unauthenticated HTTP Client	CONFIG_AND_PATH_DISCLOSURE_VERIFIED	HTTP 200 exposing PHP 5.2.4, allow_url_include=On, DOCUMENT_ROOT=/var/www, internal OS/env variables	Remote file inclusion / code execution was not triggered under non-destructive ROE	#927 (4aba7226489e5f2914d72ee53f7edf69d20082be2698f0bd94590f6d2a4f41a9)
phpMyAdmin Web Interface (/phpMyAdmin/)	Unauthenticated HTTP Client	LOGIN_GATE_ENFORCED (Control Gap: Admin Login Exposed on Network)	HTTP 200 login page reachable over cleartext HTTP	Database administrative login and SQL table access are blocked by authentication gate (not proven)	#925 (7b24a67aa62e7ec77c74621b74b8c9b9436ea43ee8ca60791263dd5bed3925f3)
MySQL Database Listener (TCP/3306)	Unauthenticated TCP Socket Client	HANDSHAKE_EXPOSED_AUTH_REQUIRED	MySQL 5.0.51a-3ubuntu5 server greeting packet received without host ACL rejection	Authenticated SQL session and schema read/write access are not established by greeting banner	#919 (e254ea452363dabc4fe8431b4403d433b962411884ba778950df1db81e72734f)

5.2 Stage 9.5 Lateral Movement Validation & Stage 9.6 CIA Impact Assessment

Stage / Dimension	Validation Status	Demonstrated Evidence & Scope Boundary
Stage 9.5 Lateral Movement	NOT_PROVEN (Single-Host Topology Discovery Only)	Anonymous SMB share enumeration (`SMB-LIST-001`) proves unauthenticated share discovery on the target asset, but does not constitute confirmed lateral movement to other systems.
Stage 9.6 Confidentiality	DEMONSTRATED (Bounded)	Share names/comments (`IPC$`, `ADMIN$`, `print$`, `tmp`), PHP runtime environment (`DOCUMENT_ROOT=/var/www`, `allow_url_include=On`) disclosed.
Stage 9.6 Integrity	PRECONDITION_IDENTIFIED (Not Actively Modified)	Identified writable share metadata (`tmp`) and `allow_url_include=On` precondition; zero bytes modified on target.
Stage 9.6 Availability	NOT_TESTED (Out of Scope per Non-Destructive ROE)	Zero service disruption; all probes completed within deterministic rate limits.

6. Four-Tier Evidence-Driven Compliance Control Mapping

Primary Finding	PCI-DSS v4.0	NIST SP 800-53 Rev 5	ISO/IEC 27001:2022	CIS Controls v8
TOMCAT-MGR-001 (Default Admin Auth)	Req 2.2.2 / 8.2.1	IA-5 / AC-6	A.5.17 / A.8.2	Control 4.7 / 5.2
SMB-LIST-001 (Samba Anonymous Enum)	Req 1.3.1 / 2.2.4	AC-3 / SC-7	A.8.20 / A.8.3	Control 3.3 / 4.1
PHPINFO-001 (Config/Path Disclosure)	Req 2.2.6 / 6.4.1	CM-6 / SI-11	A.8.9 / A.8.28	Control 4.1 / 16.11
Legacy Daemons (vsFTPd, OpenSSH, Apache)	Req 6.3.3	SI-2 / CM-8	A.8.8 (Vuln Mgmt)	Control 7.1 / 7.4

7. ENUMCORE 6-Stage CVE Applicability Validation & Threat Intelligence

CVE / CWE	Validation State	Preconditions Verified	CVSS	EPSS	CISA KEV	Applicability & Precondition Note

CVE / CWE	Validation State	Preconditions Verified	CVSS	EPSS	CISA KEV	Applicability & Precondition Note
CVE-2011-3192	CVE_CANDIDATE	No (Banner Only)	7.8	91.4%	No	Ubuntu 8.04 LTS Apache/2.2.8 banner detected; DoS verification out of scope.
CVE-2012-1823	CVE_CANDIDATE	No (Banner Only)	9.8	95.2%	YES	PHP 5.2.4 and allow_url_include=On observed via /phpinfo.php, but CGI SAPI execution mode and argument-injection behavior were not verified -> classified as CVE_CANDIDATE (CVE_CORRELATED).
CVE-2011-2523	APPLICABILITY_VALIDATED	No (Banner Only)	9.8	89.2%	No	Exact version 2.3.4 matched on TCP/21; backdoor listener trigger was not actively executed under read-only ROE.
CVE-2023-38408	CVE_CANDIDATE	No (Banner Only)	9.8	68.4%	No	Banner-only version heuristic; ssh-agent forwarding and PKCS#11 preconditions were not observed.
CVE-2017-7494	PRECONDITIONS_VALIDATED	YES	9.8	93.8%	YES	Anonymous SMB share 'tmp' enumerated on TCP/445; write-and-load payload execution intentionally not performed.
CVE-2012-2122	CVE_CANDIDATE	No (Banner Only)	7.5	88.1%	No	Banner match only on TCP/3306; authentication brute-force not executed.
CWE-693	VERSION_DETECTED	No (Banner Only)	5.5	8.0%	No	No CVE identifier associated; scored by CWE control category.
CWE-319	VERSION_DETECTED	No (Banner Only)	5.5	8.0%	No	No CVE identifier associated; scored by CWE control category.
CWE-284	VERSION_DETECTED	No (Banner Only)	5.5	8.0%	No	No CVE identifier associated; scored by CWE control category.
CWE-200	VERSION_DETECTED	No (Banner Only)	5.5	8.0%	No	No CVE identifier associated; scored by CWE control category.
CWE-287	VERSION_DETECTED	No (Banner Only)	7.5	28.0%	No	No CVE identifier associated; scored by CWE control category.
CWE-20	VERSION_DETECTED	No (Banner Only)	7.8	28.0%	No	No CVE identifier associated; scored by CWE control category.
CWE-352	VERSION_DETECTED	No (Banner Only)	5.5	8.0%	No	No CVE identifier associated; scored by CWE control category.
CWE-548	VERSION_DETECTED	No (Banner Only)	5.5	8.0%	No	No CVE identifier associated; scored by CWE control category.
CWE-538	VERSION_DETECTED	No (Banner Only)	5.5	8.0%	No	No CVE identifier associated; scored by CWE control category.

8. Prioritized Remediation Roadmap & Executed Retest Ledger (Stage 8)

Task ID	Priority	Status	Owner	Work Package Title	Platform-Accurate Fix Guidance	Verification & Closure Rule
REM-00089	P1-Urgent	open	Linux Systems & Network Engineering	Remediate DAST-VER-INTEL-TECH-00121: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): Samba smbd 3.X - 4.X [CVE_CORRELATED: CVE-2017-7494]	Upgrade Samba smbd (3.X - 4.X) to a current vendor-supported release and apply security advisories. [Affected Asset: 192.168.195.139:445 | C	Verification Test: TrePath Retest Adapter for DAST-VER-INTEL-TECH-00121 on 192.168.195.139:445 | Closure Criteria: Proof

Task ID	Priority	Status	Owner	Work Package Title	Platform-Accurate Fix Guidance	Verification & Closure Rule
REM-00090	P1-Urgent	open	Linux Systems & Network Engineering	Remediate DAST-VER-INTEL-TECH-00099: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): vsFTPd 2.3.4 [CVE_CORRELATED: CVE-2011-2523]	Upgrade vsFTPd (2.3.4) to a current vendor-supported release and apply security advisories. [Affected Asset: 192.168.195.139:21 | Consolidat	Verification Test: TrePath Retest Adapter for DAST-VER-INTEL-TECH-00099 on 192.168.195.139:21 | Closure Criteria: ProofS
REM-00091	P1-Urgent	open	Application Security & Web Platform Engineering	Remediate DAST-VER-INTEL-TECH-00098: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): PHP 5.2.4-2ubuntu5 [CVE_CORRELATED: CVE-2012-1823]	Upgrade PHP (5.2.4-2ubuntu5) to a current vendor-supported release and apply security advisories. [Affected Asset: 192.168.195.139:80 | Cons	Verification Test: TrePath Retest Adapter for DAST-VER-INTEL-TECH-00098 on 192.168.195.139:80 | Closure Criteria: ProofS
REM-00092	P1-Urgent	open	Linux Systems & Network Engineering	Remediate DAST-VER-INTEL-TECH-00100: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): SSH-2.0-OpenSSH 4.7 [CVE_CORRELATED: CVE-2023-38408]	Upgrade SSH-2.0-OpenSSH (4.7) to a current vendor-supported release and apply security advisories. [Affected Asset: 192.168.195.139:22 | Con	Verification Test: TrePath Retest Adapter for DAST-VER-INTEL-TECH-00100 on 192.168.195.139:22 | Closure Criteria: ProofS
REM-00093	P1-Urgent	open	Application Security & Web Platform Engineering	Remediate DAST-VER-INTEL-TECH-00097: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): Apache 2.2.8 [CVE_CORRELATED: CVE-2011-3192]	Upgrade Apache (2.2.8) to a current vendor-supported release and apply security advisories. [Affected Asset: 192.168.195.139:80 | Consolidat	Verification Test: TrePath Retest Adapter for DAST-VER-INTEL-TECH-00097 on 192.168.195.139:80 | Closure Criteria: ProofS
REM-00094	P1-Urgent	open	Linux Systems & Network Engineering	Remediate PORT-OPEN-23-TELNET: Service Port Open: 23/TCP (Telnet) on 192.168.195.139	Unencrypted remote terminal daemon. Disable Telnet daemon and replace with SSH. [Affected Asset: 192.168.195.139:23 | Consolidated Findings	Verification Test: TrePath Retest Adapter for PORT-OPEN-23-TELNET on 192.168.195.139:23 | Closure Criteria: ProofState t
REM-00095	P1-Urgent	open	Linux Systems & Network Engineering	Remediate PORT-OPEN-512-REXEC: Service Port Open: 512/TCP (Rexec) on 192.168.195.139	Legacy cleartext remote execution. Disable rexec. [Affected Asset: 192.168.195.139:512 | Consolidated Findings (5): PORT-OPEN-512-REXEC, DAS	Verification Test: TrePath Retest Adapter for PORT-OPEN-512-REXEC on 192.168.195.139:512 | Closure Criteria: ProofState
REM-00096	P1-Urgent	open	Linux Systems & Network Engineering	Remediate PORT-OPEN-513-RLOGIN: Service Port Open: 513/TCP (Rlogin) on 192.168.195.139	Legacy cleartext remote login. Disable rlogin. [Affected Asset: 192.168.195.139:513 | Consolidated Findings (3): PORT-OPEN-513-RLOGIN, DAST-	Verification Test: TrePath Retest Adapter for PORT-OPEN-513-RLOGIN on 192.168.195.139:513 | Closure Criteria: ProofState
REM-00097	P1-Urgent	open	Application Security & Web Platform Engineering	Remediate ZAP-20018-20018: [OWASP ZAP] Remote Code Execution - CVE-2012-1823	<p>Upgrade to the latest stable version of PHP, or use the Apache web server and the mod_rewrite module to filter out malicious requests usi	Verification Test: TrePath Retest Adapter for ZAP-20018-20018 on 192.168.195.139:80 | Closure Criteria: ProofState trans

Task ID	Priority	Status	Owner	Work Package Title	Platform-Accurate Fix Guidance	Verification & Closure Rule
REM-00098	P2-Planned	open	Linux Systems & Network Engineering	Remediate DAST-VER-INTEL-TECH-00114: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): MySQL 5.0.51a-3ubuntu5 [CVE_CORRELATED: CVE-2012-2122]	Upgrade MySQL (5.0.51a-3ubuntu5) to a current vendor-supported release and apply security advisories. [Affected Asset: 192.168.195.139:3306	Verification Test: TrePath Retest Adapter for DAST-VER-INTEL-TECH-00114 on 192.168.195.139:3306	Closure Criteria: Proo
REM-00099	P2-Planned	open	Linux Systems & Network Engineering	Remediate DAST-VER-INTEL-TECH-00118: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): ISC BIND 9.4.2 (Legacy Release)	Upgrade ISC BIND (9.4.2) to a current vendor-supported release and apply security advisories. [Affected Asset: 192.168.195.139:53	Consolid	Verification Test: TrePath Retest Adapter for DAST-VER-INTEL-TECH-00118 on 192.168.195.139:53	Closure Criteria: ProofS
REM-00100	P2-Planned	open	Application Security & Web Platform Engineering	Remediate DAST-VER-INTEL-TECH-00109: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): Rsh/Syslog (Legacy Release)	Upgrade Rsh/Syslog (legacy) to a current vendor-supported release and apply security advisories. [Affected Asset: 192.168.195.139:514	Cons	Verification Test: TrePath Retest Adapter for DAST-VER-INTEL-TECH-00109 on 192.168.195.139:514	Closure Criteria: Proof
REM-00101	P2-Planned	open	Linux Systems & Network Engineering	Remediate DAST-VER-INTEL-TECH-00126: [VER-INTEL-001] Outdated Software Component Identified (Version Fingerprint): PostgreSQL DB 8.3.0 - 8.3.7 (Legacy Release)	Upgrade PostgreSQL DB (8.3.0 - 8.3.7) to a current vendor-supported release and apply security advisories. [Affected Asset: 192.168.195.139:	Verification Test: TrePath Retest Adapter for DAST-VER-INTEL-TECH-00126 on 192.168.195.139:5432	Closure Criteria: Proo
REM-00102	P2-Planned	open	Application Security & Web Platform Engineering	Remediate PHPINFO-EP-00045: [PHPINFO-001] Exposed phpinfo.php Configuration & Path Disclosure Verified on 192.168.195.139	Remove `/phpinfo.php` and diagnostic scripts from `/var/www`, set `allow_url_include = Off` and `expose_php = Off` in `/etc/php5/apache2/php	Verification Test: curl -i http://192.168.195.139 /phpinfo.php (Test ID: PHPINFO-001)	Closure Criteria: GET /phpinfo.ph
REM-00103	P2-Planned	open	Linux Systems & Network Engineering	Remediate SMB-LIST-EP -SMB-ASSET-00008: [SMB-LIST-001] Anonymous SMB Share Enumeration Verified on 192.168.195.139:445	Harden Samba configuration in `/etc/samba/smb.conf`: set `map to guest = Never`, `restrict anonymous = 2`, and `usershare allow guests = no`	Verification Test: smbclient -L //192.168.195.139 -N -p 445 (Test ID: SMB-LIST-001)	Closure Criteria: Anonymous null-s

8.2 Deterministic Retest Execution Ledger (RTEX-xxxxx)

Retest Key	Target Finding	Execution Status	Resulting Proof State	Evidence Artifact	Verification Notes
RTEX-STANDBY	All Open Findings	AWAITING_PATCH	PENDING_RETEST	EvidenceCore Ready	Use POST /api/v1/findings/{id}/retest/execute after applying remediation to record cryptographic closure proof.

9. EvidenceCore Cryptographic Integrity, Consistency Score & Pre-Render Quality Gate

Gate ID	Verification Domain	Dynamic Acceptance Rule & Live Scan Telemetry	Status
AT-2.1-01	Root-Cause Deduplication	107 raw observations deduplicated into 36 unique root-cause security findings.	**PASSED**
AT-2.1-02	Sensor Standby Separation	OPENVAS-SENSOR-STANDBY isolated into Scanner Health Telemetry (1 sensor event).	**PASSED**
AT-2.1-03	Granular SMB Proof Taxonomy	SMB-LIST-001 reports SHARE_ENUMERATION_VERIFIED without claiming write access or cross-host pivot.	**PASSED**
AT-2.1-04	Linux/Samba Remediation	Samba smb.conf directives (map to guest = Never, restrict anonymous = 2) enforced.	**PASSED**
AT-2.1-05	PHPInfo & CGI Precondition	PHPINFO-001 classified as CONFIG_AND_PATH_DISCLOSURE_VERIFIED; CVE-2012-1823 requires CGI SAPI proof.	**PASSED**
AT-2.1-06	Admin Auth Reconciliation	**Executive & Section 1.2 agree: CONFIRMED_ADMIN_AUTH = 0, IMPACT_VERIFIED = 2.**	**PASSED**
AT-2.1-07	CVE Precondition Gate	Raw KEV (5) -> Unique KEV (2); version-only CVEs discounted 75%.	**PASSED**
AT-2.1-08	AttackGraph & Endpoint Ports	All 36 consolidated findings resolve to valid non-zero TCP ports (Port-0 count = 0).	**PASSED**
AT-2.1-09	7-Dimension Risk Calibration	7 risk dimensions sum (75.9/100) matches headline score (75.9/100 = 7.6/10).	**PASSED**
AT-2.1-10	Evidence Consistency Score	Evidence Consistency Score = 100.0% (Shared HTTP artifacts explicitly annotated).	**PASSED**

10. Autonomous 8-Stage Orchestration Architecture & Benchmark Summary

Stage	Engine Module	Execution Outcome
Stage 1-2	Scope & Surface Discovery	Verified host 192.168.195.139, 15 TCP services, and 10 HTTP endpoints.
Stage 3	ENUMCORE 6-Stage CVE Engine	Mapped CPEs and separated precondition-verified KEVs from banner-only candidates.
Stage 4-5	Policy Engine & Safe PoC Probes	Executed SMB-LIST-001, SMB-READ-001, PHPINFO-001, and TOMCAT-MGR-001 within RoE.
Stage 6-7	Proof Validator & AttackGraph	Assigned granular proof substates and built per-edge evidence-backed attack chains.
Stage 8	RiskEngine 2.1 & RTEX Ledger	Computed 7-dimension risk (7.6/10) and generated platform-aware remediation tasks.

11. Sign-Off & Deliverables Attestation

Role	Attestation Statement	Signature / Timestamp
Lead Penetration Tester	All findings and PoC transcripts verified against EvidenceCore SHA-256 seals.	SIGNED | 2026-11-01 22:30 UTC
Principal Security Architect	26-Rule Quality Gate and TrePath 2.1 AT-2.1-01..10 acceptance checks passed.	VERIFIED | 2026-11-01 22:30 UTC
Client System Owner	Acknowledges receipt of prioritized remediation roadmap and RTEX retest workflow.	_____